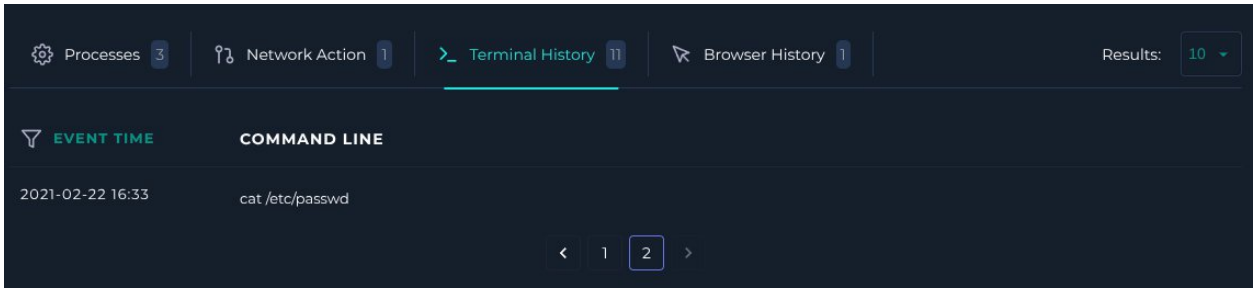
Event Information:

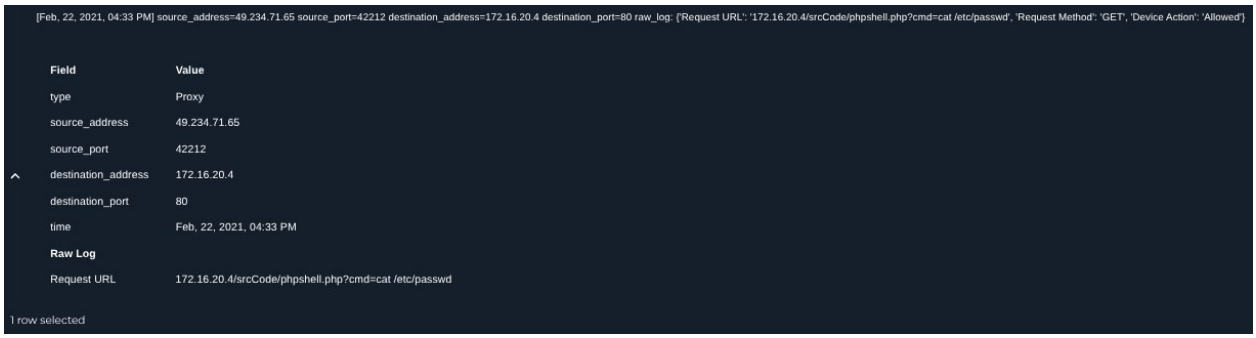
EventID :
63
Event Time :
Feb, 21, 2021, 05:02 PM
Rule :
SOC129 - Successful Local File Inclusion
Level :
Security Analyst
Source Address :
49.234.71.65
Source Hostname :
unknown
Destination Address :
172.16.20.4
Destination Hostname :
gitServer
Username :
www-data
Request URL :
172.16.20.4/srcCode/show.php?page=../../../../../../../etc/passwd
User Agent :
Mozilla/5.0 (Macintosh; Intel Mac OS X 10_14_4) AppleWebKit/605.1.15 (KHTML, like Gecko)
Device Action :
Allowed

Analysis Steps:

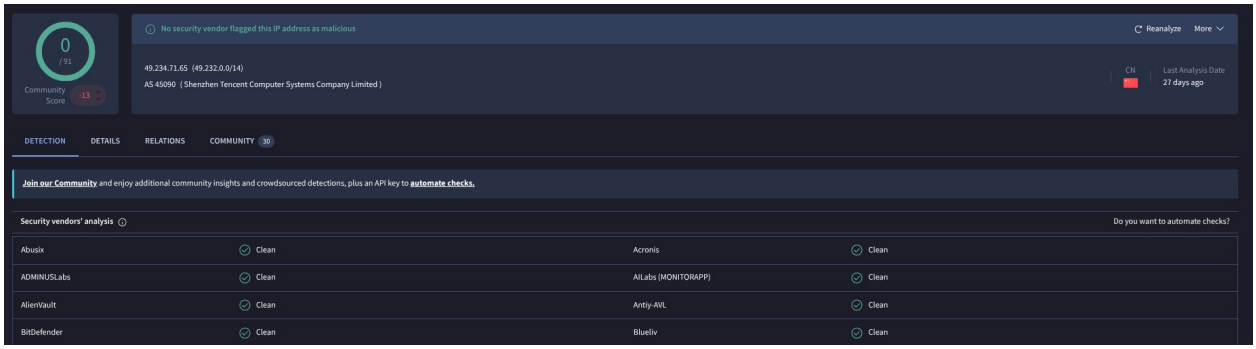
On endpoint analysis we can see the etc/passwd was accessed but it was not due to the LFI attempt.



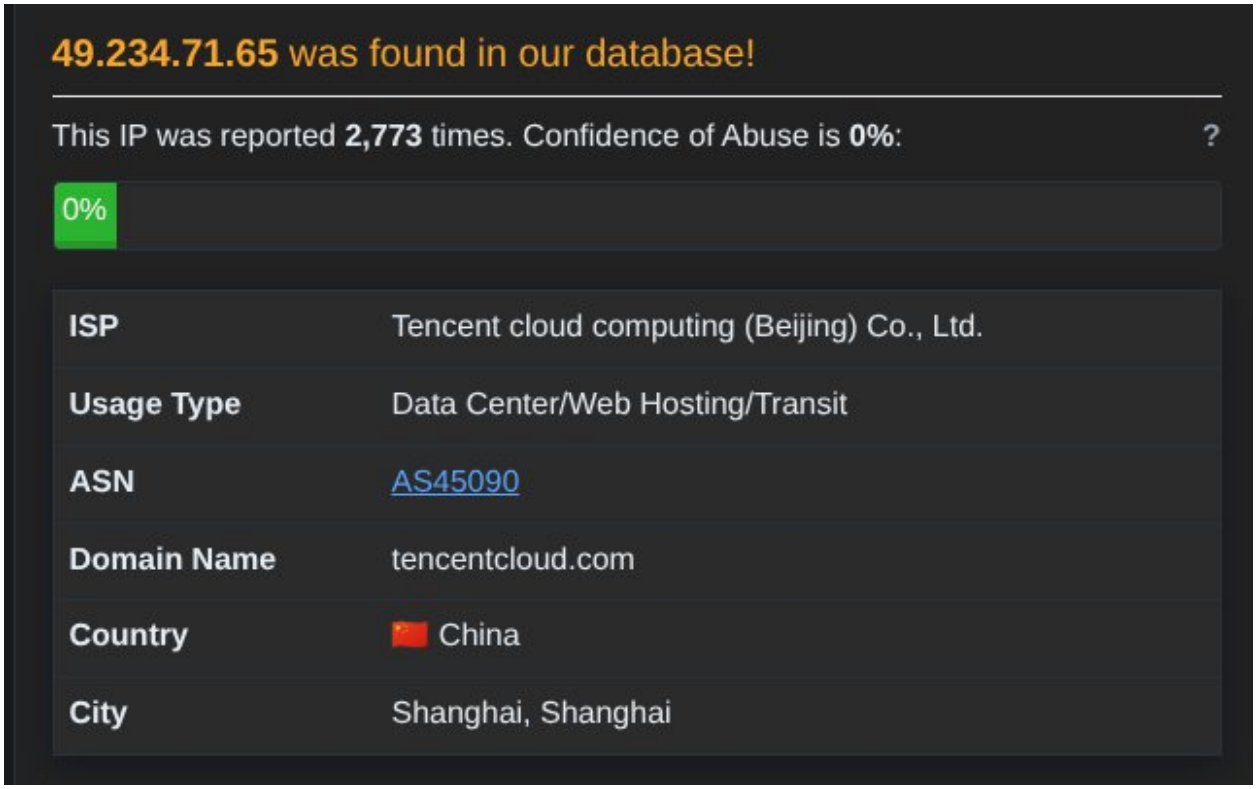
It was achieved later on via a different method.



The offending IP is not in our CTI database and is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a Chinese address associated with 49[.]234.71.65 AS 45090 (Shenzhen Tencent Computer Systems Company Limited). 0/91 security vendors flagged this IP address as malicious as of 27 days ago.



On AbuseIPDB this IP was reported 2,733 times with a 0% confidence of abuse.



Based on following Playbook procedure and the analysis of available information, this alert is determined to be a False Positive.

Report:

Incident Summary

Analysis confirms a False Positive classification for the Local File Inclusion (LFI) alert. Although an external attacker attempted a directory traversal attack, endpoint analysis reveals this specific attempt was not the root cause of the compromise. The attacker did successfully read the password file, but this was achieved via a different attack method.

Incident Details

- **Alert Name:** SOC129 - Successful Local File Inclusion
- **Attacker IP:** 49[.]234.71.65
- **Target Host:** gitServer (172[.]16.20.4)
- **User Account:** www-data
- **Request URL:** 172[.]16.20.4/srcCode/show.php?page=../../../../../../../etc/passwd
- **Device Action:** Allowed

Analysis and Evidence

- **LFI Attempt:** On Feb 21 at 05:02 PM, the attacker attempted to use directory traversal (../../../../../../../etc/passwd) within the page= parameter of the show.php endpoint.
- **Execution Disconnect:** While the firewall permitted the traffic, the endpoint analysis confirmed the /etc/passwd file was not accessed due to this specific LFI attempt.
- **Secondary Compromise:** Terminal history and proxy logs show the /etc/passwd file was eventually accessed, but much later, at 16:33 on Feb 22.
- **Alternative Attack Vector:** Telemetry explicitly shows the file was read via a web shell command execution, recorded in the raw logs as 172[.]16.20.4/srcCode/phpshell.php?cmd=cat /etc/passwd.

Threat Intelligence

- **Infrastructure OSINT:** The source IP 49[.]234.71.65 is external, located in China, and assigned to Tencent Cloud (AS 45090).
- **IP Reputation:** VirusTotal currently flags the IP with 0/91 malicious detections. AbuseIPDB lists 2,773 historical reports, though it currently has a 0% confidence of abuse score.
- **Internal Correlation:** There is no record of authorised penetration testing from this IP in internal communications, and it is not present in the internal CTI database.

Actions Taken

1. Analysed web requests and endpoint terminal history to accurately track the attacker's timeline and actions.
2. Determined that while the system was ultimately compromised, this specific LFI alert triggered on a failed attempt.
3. Classified the alert as a False Positive in the strict context of the "Successful Local File Inclusion" rule.
4. Documented the subsequent web shell compromise (phpshell.php) to ensure proper containment, patching, and credential rotation steps are taken for the actual vector of infection.

Let’s Defend Result

